

Industrial Security (Master)

Exercise Sheet – Section 01 Firmware Reverse Engineering

Exercise 1.1 – Source and Verify

Pick a consumer or industrial router image you can lawfully obtain (e.g. OpenWrt, a discontinued home router model, or vendor partner programme). Document:

1. How you obtained the image.
2. Vendor-published hash and your local hash (match?).
3. The license / legal basis under which you analyse it.

Exercise 1.2 – Triage

On the same image, run `binwalk -e` and then:

- Identify CPU architecture and endianness (use `binwalk -A, file`).
- List bootloader, kernel, root filesystem (with offsets).
- Mount the root filesystem and dump `/etc/passwd`, `/etc/shadow`, and any `init` scripts of interest.

Exercise 1.3 – Strings to Findings

Run `strings -n 8` over the image, then:

1. Search for words like `admin`, `password`, `token`, `secret`.
2. Identify three candidate hard-coded secrets and the binary they live in.
3. For each, propose how an asset owner could mitigate without a firmware update.

Exercise 1.4 – Ghidra Mini-Reverse

Open the most “interesting” binary in Ghidra. Pick one symbol (e.g. `login`, `check_password`, `handle_modbus`) and:

1. Read the decompiled C.
2. Document one weakness (CWE-class) you observe.
3. Sketch the patch you would propose to the vendor.

Exercise 1.5 – Disclosure Letter

Write the email you would send to a vendor PSIRT for a finding from Exercise 1.4. Include:

- Affected product, firmware version, hash.
- Reproduction steps (minimal, no exploit code).
- Proposed disclosure timeline (vendor / CERT / public).
- Your contact details and PGP fingerprint.

Caution

Only analyse firmware you have a legal basis to handle. Never test the resulting findings against production devices that are not yours.